# THIRD PARTY AND VENDOR RISK ASSESSMENT PROCESS

*SOP-013 | Standard Operating Procedure | Issued under POL-013*

**Document ID:** SOP-013
**Version:** 1.0 — DRAFT
**Parent Policy:** POL-013 — Third Party and Vendor Risk Policy
**Classification:** Internal Use
**Owner:** Information Security
**Co-Owner:** Legal / Procurement
**Effective Date:** [DATE]
**Review Date:** [DATE + 1 Year]

**CONFIDENTIAL — FOR INTERNAL USE ONLY**

# Document Control

| Field | Detail |
|---|---|
| Document Title | Third Party and Vendor Risk Assessment Process |
| Document ID | SOP-013 |
| Version | 1.0 — DRAFT |
| Parent Policy | POL-013 — Third Party and Vendor Risk Policy |
| Related Documents | POL-004 (Privacy), POL-005 (System Classification), POL-006 (CSV), POL-008 (Access Control), POL-009 (PAM), POL-010 (IS Risk), POL-012 (Incident Response), POL-014 (Audit Trail), SOP-004 (DPIA), SOP-006 (Validation), SOP-008 (Access Control), SOP-009 (PAM), SOP-010 (IS Risk Assessment), SOP-012 (Incident Response), EXC-001 (Exception Management), RACI-001 |
| Owner | Information Security Manager |
| Co-Owner | Legal / Procurement |
| Effective Date | [DATE] |
| Next Review Date | [DATE + 1 Year] |

**IMPORTANT:** No vendor may access [Company Name] systems or process [Company Name] data until all pre-engagement requirements for their tier are satisfied. There is no provisional access exception — not for urgency, not for existing relationships. An organisation cannot consent to data processing on behalf of data subjects in advance of a lawful basis being confirmed.

## Revision History

| Version | Date | Author | Description |
|---|---|---|---|
| 0.1 | [DATE] | [Author] | Initial draft |
| 1.0 | [DATE] | [Author] | Issued for review |

# 1. Purpose

This SOP defines the end-to-end process for assessing, onboarding, monitoring, and offboarding third-party vendors and partners — wherever a vendor accesses [Company Name] systems, processes data on [Company Name]'s behalf, or provides services that affect [Company Name]'s regulatory compliance posture. It operationalises POL-013 by establishing the specific steps, due diligence requirements by vendor tier, contractual checklist, GxP vendor qualification process, data transfer mechanism assessment, and ongoing monitoring cadence.

Vendor risk management is not a procurement or legal function alone. It is a joint accountability across Information Security (security risk), Legal (contractual and regulatory), Compliance / QA (GxP qualification), DPO (privacy and data transfer), and the business relationship owner (commercial and operational). This SOP defines who does what and in what sequence.

# 2. Scope

This SOP applies to all third-party relationships where the vendor:

- Accesses any [Company Name] system — including read-only access, support access, or monitoring access
- Processes personal data or PHI on [Company Name]'s behalf (as a data processor under GDPR or a Business Associate under HIPAA)
- Provides services that support GxP activities (as a GxP vendor or contract research/manufacturing organisation)
- Provides services that are in scope for SOX ITGC controls

The following are outside scope of this SOP: vendors supplying goods with no system access and no data processing (e.g., office supplies, non-IT equipment); publicly available SaaS tools used by individuals for non-regulated work with no [Company Name] data; and intra-group transactions with affiliated entities covered under a separate intra-group data processing agreement.

# 3. Roles and Responsibilities

| Role | Responsibility in This Process |
|---|---|
| Information Security Manager | Process lead for vendor risk assessment. Assigns vendor tier. Conducts or commissions security due diligence. Approves vendor security posture. Maintains vendor risk register. Coordinates ongoing monitoring. |

| Role | Responsibility in This Process |
|---|---|
| Legal / Procurement | Negotiates and executes contractual requirements (DPA, BAA, Technical Agreement, right to audit). Confirms contractual requirements are met before onboarding. Manages contract renewals and terminations. |
| Relationship Owner | The business sponsor for the vendor engagement. Submits the vendor onboarding request. Confirms the scope and purpose of the engagement. Accountable for the commercial relationship. Participates in annual reassessment. |
| Compliance / QA | GxP vendor qualification process (Section 7). Reviews and approves Technical Agreement for GxP vendors. Conducts or oversees GxP vendor audits. Confirms qualification status before and during engagement. |
| DPO | Confirms GDPR data processing requirements. Reviews and approves DPA. Confirms international transfer mechanism before any cross-border transfer begins. Reviews DPIA for high-risk processing (SOP-004). |
| Data Custodian (IT) | Implements and manages vendor access per SOP-008 and SOP-009. Confirms access scope is limited to the approved systems and functions. Revokes access on offboarding instruction. |
| CISO | Approves vendor risk assessment for Tier A vendors. Reviews annual Tier A reassessment outputs. |

# 4. Vendor Tiering

Every vendor in scope of this SOP is assigned a risk tier at the point of onboarding. Tier assignment is driven by the POL-005 classification of the systems the vendor accesses and the nature of the data they process. The tier determines the due diligence depth, contractual requirements, and ongoing monitoring intensity.

| Tier | Trigger Criteria | Examples |
|---|---|---|
| Tier A — Critical | Access to any Tier 1 system; access to any GxP system; processing of Special Category personal data or PHI; system administration access to any Tier 2 system; sub-processor of another Tier A vendor handling [Company Name] personal data. | Cloud infrastructure provider (AWS/Azure/GCP); LIMS/EBR/MES vendor with system access; CRO processing clinical trial data; outsourced SOC with Tier 1 access; payroll processor handling health data. |
| Tier B — High | Access to Tier 2 systems; access to SOX ITGC systems; processing of personal data at volume (>5,000 data subjects) without Special Category; IT managed service provider without Tier 1 access. | ERP vendor with standard user access; HR SaaS platform; IT helpdesk provider; email security vendor with mail flow access. |
| Tier C — Medium | Access to Tier 3 systems only; contractor or consultant personnel with standard user access; processing of limited personal data (staff records only) with no Special Category; vendors providing professional services with incidental data exposure. | Facilities management contractor with office system access; recruitment agency with limited staff data; training platform provider. |
| Tier D — Low / Out of Scope | No system access and no data processing beyond publicly available information. Assessment under this SOP is not required — basic supplier onboarding only. | Office supplies vendor; printed stationery supplier; non-IT equipment vendor. |

Tier re-assessment is mandatory whenever the vendor's scope changes — a Tier C vendor that is granted access to a Tier 1 system becomes Tier A immediately and must complete Tier A due diligence before the expanded access is provisioned. The Relationship Owner is responsible for notifying Information Security of any scope change.

# 5. Pre-Engagement Assessment

**Step 01**

### Vendor Onboarding Request

The Relationship Owner submits a Vendor Onboarding Request to Information Security and Legal, covering: — Vendor name, registered address, and primary contact — Nature of the engagement: what service, what access, what data — Systems the vendor will access (referenced by system ID from the System Register where possible) — Data to be processed: categories, volumes, sensitivity tier (referencing POL-001 / WI-001) — Whether the engagement involves GxP activities — Whether personal data will be processed (GDPR / HIPAA) — Proposed engagement start date and duration — Whether international data transfers are anticipated  Information Security assigns the vendor tier (Section 4) within 3 business days of request receipt. Tier assignment is confirmed to the Relationship Owner and Legal.

Responsible
**Relationship Owner → Information Security / Legal**

**Step 02**

### Due Diligence — Tier A

Responsible

**NOTE:** Tier A due diligence is the most extensive. All items below must be completed and reviewed by Information Security Manager before onboarding proceeds. No single item may be waived without an EXC-001 exception approved by the CISO.

| Due Diligence Item | Requirement | Acceptable Evidence |
|---|---|---|
| Information Security Certification | ISO 27001 or SOC 2 Type II — current, in scope for the services being procured | Certificate copy + scope statement confirming coverage of the service. Not more than 12 months old. |
| Penetration Test | Annual penetration test of systems in scope for the engagement | Executive summary of most recent pentest. Not more than 12 months old. Confirmed that critical and high findings are remediated or on a documented remediation timeline. |
| Security Questionnaire | Detailed security questionnaire covering: data handling, encryption in transit and at rest, access controls, incident detection, sub-processor management | Completed questionnaire reviewed and scored by Information Security Manager. Gaps assessed as risks. |
| Sub-processor Mapping | Complete list of sub-processors who will handle [Company Name] data | Sub-processor list with names, locations, data categories handled, and applicable transfer mechanisms. |
| Financial Due Diligence | Assessment of vendor financial stability — a financially distressed vendor cannot maintain security controls | Company accounts review or credit check. For Tier A GxP vendors: evidence of operational continuity plan. |
| DPIA | Where processing is high-risk for data subjects (Annex II GDPR criteria) | DPIA completed per SOP-004, reviewed by DPO, with Compliance/QA co-review for GxP-adjacent processing. |

| Due Diligence Item | Requirement | Acceptable Evidence |
|---|---|---|
| GxP Vendor Qualification | If GxP systems or data are in scope | Per Section 7 of this SOP — qualification must be complete before GxP system access is provisioned. |
| International Transfer Mechanism | If personal data will flow outside the EEA/UK | DPO confirms mechanism (adequacy decision, SCCs + TIA, UK IDTA) before transfer begins. See Section 8. |

**Step 03** — **Due Diligence — Tier B** — Responsible

| Due Diligence Item | Requirement |
|---|---|
| Security Certification | ISO 27001 or SOC 2 Type II — or completion of [Company Name] security questionnaire if certification not held. Not more than 18 months old. |
| Security Questionnaire | Standard security questionnaire reviewed by Information Security. Major gaps treated as risks in vendor risk register. |
| Sub-processor Identification | Identification of key sub-processors handling personal data. Full mapping not required unless DPO assesses high risk. |
| DPIA | Required where DPO assesses high risk processing. Completed per SOP-004. |
| International Transfer | DPO confirms transfer mechanism where personal data transferred outside EEA/UK. |

**Step 04** — **Due Diligence — Tier C** — Responsible

Tier C due diligence is proportionate to the limited risk profile. Information Security reviews a short-form questionnaire covering: data handling, access scope confirmation, and basic security hygiene (MFA, patching). DPO confirms a lawful basis for any personal data processing. No certification requirement unless processing volume warrants it.

**Step 05**

### Due Diligence Assessment and Decision

Information Security Manager reviews all due diligence outputs and produces a Vendor Risk Assessment summary: — Vendor tier confirmed — Due diligence items: complete / incomplete / accepted with noted gap — Material findings from security questionnaire and pentest review — Residual risk rating: Low / Medium / High / Critical — Recommendation: Approve / Approve with conditions / Reject Approval authority: — Tier A: CISO approval — Tier B: Information Security Manager approval — Tier C: Information Security Manager approval (delegable to team member for low-risk) A rejected vendor assessment may be resubmitted once the vendor has remediated the identified gaps. Provisional access while gaps are remediated is not permitted.

Responsible
**Information Security Manager / CISO (Tier A)**

# 6. Contractual Requirements

Contractual requirements are non-negotiable — they reflect regulatory obligations, not commercial preferences. Legal confirms all required agreements are executed before onboarding proceeds. The Relationship Owner may not commence the engagement before Legal confirmation.

| Agreement | Trigger | Key Requirements | Consequence of Absence |
|---|---|---|---|
| Data Processing Agreement (DPA) GDPR Art. 28 | Any processing of personal data on [Company Name]'s behalf | Processing purpose and scope; data subject categories; processing instructions; sub-processor obligations; security measures; audit rights; deletion/return on termination; breach notification SLA: 24hr (Tier A), 48hr (Tier B), 72hr (Tier C) | Processing is unlawful under GDPR. Engagement cannot begin. Regulatory fine risk. |
| Business Associate Agreement (BAA) HIPAA | Any access to or processing of PHI | Permitted uses and disclosures; safeguards; breach notification; sub-contractor BAAs; PHI return/destruction; audit rights | Processing is unlawful under HIPAA. Engagement cannot begin. Regulatory fine risk. |
| Technical Agreement GxP | Any GxP vendor (Tier A with GxP scope) | SDLC controls; validation documentation obligations; change notification requirements (vendor must notify [Company Name] before any change affecting validated systems); sub-contracting restrictions; regulatory inspection cooperation; audit rights | Vendor cannot be used for GxP activities. GxP vendor qualification (Section 7) cannot be completed without an executed Technical Agreement. |
| Right to Audit | Tier A and Tier B vendors | Right to audit vendor security controls and data processing with reasonable notice (typically 30 days for scheduled audits, 5 days for cause audits). Audit scope covers: security controls, data handling, sub-processor use, compliance with the DPA/BAA/Technical Agreement. | Loss of audit assurance. For GxP vendors: a right to audit is a regulatory expectation (EU Annex 11) — its absence is a potential inspection finding. |
| Information | All Tier A and Tier | Minimum security standards: | Security obligations not |

| Agreement | Trigger | Key Requirements | Consequence of Absence |
|---|---|---|---|
| Security Schedule (incorporated into MSA) | B vendors | encryption requirements, MFA requirements, incident notification SLA, vulnerability management SLA, personnel security, access control requirements, penetration testing cadence | contractually enforceable. |

**NOTE:** Contract templates for DPA, BAA, Technical Agreement, and Information Security Schedule are maintained by Legal. Do not negotiate material deviations from these templates without Legal and DPO (for DPA/BAA) or Compliance/QA (for Technical Agreement) review and approval. Vendor-proposed DPA templates are acceptable only where Legal confirms they meet GDPR Art. 28 requirements in full — which most do not.

# 7. GxP Vendor Qualification

GxP vendor qualification is a five-step process that runs in parallel with the general due diligence process (Section 5) but has its own completion criteria and evidence requirements. All qualification evidence is filed in the VMF of the GxP system the vendor supports (per SOP-006).

| | | |
|---|---|---|
| **Step 01** | **Vendor Assessment**<br>Compliance / QA conducts or oversees a GxP-specific vendor assessment covering: — Quality Management System (QMS): does the vendor have a QMS appropriate for GxP activities? Is it certified (ISO 9001, GMP-licensed)? — Validation practices: how does the vendor manage computer system validation? Is their SDLC compliant with GAMP 5? — Audit trail management: how does the vendor implement and protect audit trails in GxP systems? — Change notification: does the vendor have a process for notifying customers of changes that may affect validated systems? — Regulatory inspection history: has the vendor been subject to GxP regulatory inspections? What findings? How were they resolved? — Sub-contracting: does the vendor sub-contract any GxP-relevant activity? Are sub-contractors qualified? Assessment output: Vendor Assessment Report, retained in VMF. | Responsible<br>**Compliance / QA** |
| **Step 02** | **Technical Agreement**<br>Compliance / QA drafts and negotiates the Technical Agreement in conjunction with Legal. The Technical Agreement is distinct from the commercial MSA — it is a quality agreement that creates obligations specific to GxP compliance: Mandatory Technical Agreement contents: — Scope of GxP services / software being provided — SDLC and validation obligations: vendor commits to maintaining validation documentation per GAMP 5 or equivalent — Change notification: vendor | Responsible<br>**Compliance / QA / Legal** |

| | | |
|---|---|---|
| | commits to notifying [Company Name] of any change that may affect the validated state of systems used by [Company Name] — with a minimum of [30 days / as agreed] advance notice for planned changes — Sub-contracting: vendor identifies any sub-contractors performing GxP-relevant activities and commits to qualifying them — Regulatory inspection: vendor cooperates with [Company Name] in providing evidence to regulatory inspectors; vendor notifies [Company Name] of any regulatory inspection finding that affects services provided to [Company Name] — Audit rights: [Company Name] right to audit vendor's GxP controls with [30 days] notice — Termination and data return: on termination, vendor provides complete GxP records and audit trails in a readable format within [30 days]  Technical Agreement signed by Compliance / QA Director and vendor equivalent before any GxP system access is provisioned. | |
| **Step 03** | **Qualification Audit**<br>For Tier A GxP vendors, a qualification audit is conducted before the vendor is used for GxP activities:  Audit scope: — QMS implementation and documentation — Validation evidence for systems used by [Company Name] — Audit trail implementation and immutability for GxP data — Change control process for GxP systems — Personnel training records for staff accessing [Company Name] GxP data — Physical and logical security for GxP data  Audit may be conducted by Compliance / QA directly or by a qualified third-party auditor appointed by [Company Name]. Remote audit is acceptable for initial qualification where travel is impractical — on-site audit required at least every 3 years for Tier A GxP vendors.  Audit Report: produced within 30 days of audit completion. Filed in VMF. Material findings require a vendor CAPA plan with agreed timelines before qualification is confirmed. | Responsible<br>**Compliance / QA** |
| **Step 04** | **Qualification Confirmation**<br>On satisfactory completion of Steps 1–3: 1. Compliance / QA Director issues a Vendor Qualification Certificate: vendor name, scope of qualification, qualification date, next re-qualification date 2. Qualification Certificate filed in VMF and in the Vendor Risk Register 3. GxP system access provisioned per SOP-008 and SOP-009 — named individual vendor accounts only, scoped to the qualified engagement 4. Vendor added to the GxP Qualified Vendor List maintained by Compliance / QA No GxP activities may involve this vendor before the Qualification Certificate is issued. | Responsible<br>**Compliance / QA Director** |
| **Step 05** | **Annual Re-Qualification**<br>GxP vendor qualification must be maintained. Annual re-qualification activities: — Review of vendor change notifications received since last qualification: assess impact on validated state, confirm all changes were processed through [Company Name] change management (SOP-007) — Review of vendor audit trail from any GxP system access in the period — Confirmation that ISO/QMS certification remains current — Confirmation that no regulatory findings affecting the vendor's GxP services have | Responsible<br>**Compliance / QA** |

occurred — Re-qualification audit: full on-site audit at minimum every 3 years; desk-based review in intervening years  Annual re-qualification output: Re-Qualification Certificate or a De-Qualification notice. Filed in VMF. If de-qualified: vendor GxP system access suspended immediately pending remediation and re-qualification.

# 8. International Data Transfer Assessment

Where a vendor will transfer or access personal data outside the EEA or UK, the DPO must confirm an appropriate transfer mechanism before the transfer begins. The assessment is conducted as part of the pre-engagement process for new vendors and reviewed annually for existing vendors.

| Transfer Mechanism | Applicability | Process | Limitations |
|---|---|---|---|
| Adequacy Decision | Transfer to a country with a current EU or UK adequacy decision (e.g., Japan, Canada (commercial), New Zealand, Switzerland, US (Data Privacy Framework)) | DPO confirms the specific adequacy decision is current and in force. No additional safeguards required. DPO records the basis. | Adequacy decisions can be revoked. DPO monitors for changes. Current US adequacy (DPF) is subject to legal challenge — DPO assesses current status at each annual review. |
| Standard Contractual Clauses (SCCs) + Transfer Impact Assessment (TIA) | Transfer to any country without adequacy where SCCs can provide adequate protection after a TIA | DPO confirms applicable SCC module (Controller-to-Processor or Processor-to-Processor). TIA conducted: law and practice of recipient country assessed for risk to data subjects. High-risk jurisdictions require supplementary measures. SCCs incorporated into DPA. | TIA must be documented and defensible. For transfers to high-surveillance jurisdictions (e.g., China, Russia), supplementary measures (e.g., encryption with keys held in EEA) are required — SCCs alone are insufficient. |
| UK International Data Transfer Agreement (IDTA) | Transfers from UK to countries without UK adequacy | DPO confirms IDTA is appropriate. IDTA incorporated into or appended to the DPA. | UK IDTA is distinct from EU SCCs — both may be required where the vendor processes data subject to both UK GDPR and EU GDPR. |
| Binding Corporate Rules (BCRs) | Intra-group transfers within a multinational | DPO reviews BCR approval certificate and confirms scope covers the data | BCRs are vendor-specific and only applicable to intra-group transfers — |

| Transfer Mechanism | Applicability | Process | Limitations |
|---|---|---|---|
| | vendor group where the vendor has approved BCRs | processing in question. | they do not cover transfers to sub-processors outside the group. |

**IMPORTANT:** The DPO must confirm the transfer mechanism before the first transfer — including during testing and onboarding. 'We'll sort the transfer mechanism once we're live' is not acceptable: the transfer of personal data outside the EEA/UK without a lawful mechanism is a GDPR violation at the moment it occurs.

# 9. Ongoing Monitoring

| Activity | Tier A Frequency | Tier B Frequency | Tier C Frequency | Owner |
|---|---|---|---|---|
| Annual full reassessment (due diligence refresh) | Annual | Annual | At contract renewal | Information Security Manager |
| Security certification renewal confirmation (ISO 27001 / SOC 2 Type II) | On certificate renewal — confirm new certificate received and scope maintained | On certificate renewal | N/A | Information Security |
| GxP re-qualification | Annual + 3-yearly on-site audit | N/A (Tier B not GxP) | N/A | Compliance / QA |
| Privileged access review | Monthly (per SOP-009) | Quarterly (per SOP-009) | At engagement renewal | Information Security / Data Custodian IT |
| Contract review | Annual — confirm DPA, BAA, Technical Agreement remain current | Annual | At renewal | Legal |
| Threat intelligence monitoring | Continuous — CISO receives | Periodic — quarterly threat | N/A | Information Security |

| Activity | Tier A Frequency | Tier B Frequency | Tier C Frequency | Owner |
|---|---|---|---|---|
| | vendor-specific threat alerts for Tier A vendors | bulletin | | |
| Financial health review | Annual — for Tier A vendors providing critical services | N/A | N/A | Procurement / Relationship Owner |
| Sub-processor change review | On notification — vendor must notify sub-processor changes per DPA | On notification | N/A | DPO / Information Security |

Ongoing monitoring findings — security gaps, sub-processor changes, certification lapses, qualification issues — are documented in the Vendor Risk Register and escalated to the IS Risk Register (SOP-010) where they represent a residual risk above Low. Material findings may trigger an out-of-cycle full reassessment.

# 10. Vendor Incident Response

When a vendor reports or [Company Name] identifies a security incident involving a vendor, the following applies immediately — in parallel with SOP-012:

- Vendor access suspended: all vendor accounts suspended immediately per SOP-008 pending investigation. Privileged vendor access: SOP-009 procedure activated.
- GDPR clock: the 72-hour notification clock runs from the moment [Company Name] Information Security is aware of a potential personal data breach — regardless of when the vendor notified [Company Name]. Vendor notification delay does not extend the regulatory deadline.
- GxP impact assessment: Compliance / QA notified immediately. Validated state assessment per SOP-006 for any GxP systems the vendor had access to.
- Vendor breach notification SLA: if the vendor has not notified [Company Name] within their contractual notification SLA (24hr Tier A, 48hr Tier B, 72hr Tier C), this is a contract breach and Legal is notified.

- Post-incident: PIR output (SOP-012) includes vendor-specific findings. Vendor reassessment triggered. Re-qualification triggered for GxP vendors. Contract review for material failures.

# 11. Offboarding

| | | |
|---|---|---|
| **Step 01** | **Offboarding Trigger**<br>Offboarding is triggered by: contract termination (planned or early), vendor de-qualification (GxP), vendor security incident resulting in engagement termination, or vendor insolvency. The Relationship Owner notifies Information Security, Legal, and Compliance / QA (if GxP vendor) of the offboarding at least 30 days before the end date where planned — immediately for unplanned terminations. | Responsible<br>**Relationship Owner** |
| **Step 02** | **Access Revocation**<br>Data Custodian (IT) revokes all vendor access on the last day of the engagement — or immediately for unplanned terminations: — All named vendor user accounts disabled (SOP-008 leaver procedure) — All vendor privileged accounts revoked (SOP-009) — VPN and remote access revoked — API keys and integration credentials rotated — Vendor accounts removed from all systems within 5 business days Access revocation confirmation sent to Information Security Manager and Relationship Owner. | Responsible<br>**Data Custodian (IT)** |
| **Step 03** | **Data Destruction and Return**<br>Legal confirms data handling obligations on termination per the DPA/BAA: — [Company Name] personal data: vendor provides written confirmation of destruction or return within 30 days of termination — PHI: destroyed or returned within 30 days per BAA — GxP records held by vendor: returned in a readable, complete format including audit trails, within 30 days. Completeness confirmed by Compliance / QA before Validation Closure Report is issued. — Failure to provide destruction confirmation within 30 days: Legal and Information Security notified. Potential DPA/BAA breach. | Responsible<br>**Legal / DPO / Compliance QA** |
| **Step 04** | **GxP Validation Closure**<br>For GxP vendors, Compliance / QA issues a Validation Closure Report: — Confirms all GxP records have been returned or transferred to a replacement validated system — Confirms audit trails for the engagement period are preserved and accessible — Confirms Technical Agreement is formally closed — VMF updated: vendor section closed with closure date and Validation Closure Report reference — Vendor removed from GxP Qualified Vendor List | Responsible<br>**Compliance / QA Director** |

| Step 05 | **Vendor Risk Register Update**<br>Information Security updates the Vendor Risk Register: — Vendor status: Offboarded — Offboarding date, reason, and access revocation confirmation — Data destruction confirmation reference — Any outstanding risks from the engagement noted for monitoring — Vendor Risk Register entry retained for 7 years per POL-002 | Responsible<br>**Information Security Manager** |
|---|---|---|

# 12. Related Documents

| Document ID | Title | Relationship |
|---|---|---|
| POL-013 | Third Party and Vendor Risk Policy | Parent policy — this SOP operationalises POL-013 |
| POL-004 | Privacy Policy | DPA and transfer mechanism requirements derive from POL-004; DPIA triggered for high-risk vendor processing per SOP-004 |
| POL-005 | System Classification Policy | System tier of systems the vendor accesses is the primary driver of vendor tier assignment |
| POL-006 | CSV Policy | GxP vendor qualification (Section 7) is coordinated with SOP-006 validation lifecycle; Technical Agreement and Vendor Assessment Report are VMF deliverables |
| POL-008 | Access Control Policy | Vendor access provisioned and deprovisioned per SOP-008; all vendor users are named individuals |
| POL-009 | PAM Policy | Vendor privileged access governed by SOP-009 — JIT access mandatory for Tier A vendor privileged access to Tier 1/GxP systems |
| POL-010 | IS Risk Policy | Vendor risk findings feed IS Risk Register via SOP-010 quarterly consolidation; Tier A vendor risks entered directly |
| POL-012 | Incident Response Policy | Vendor security incidents activate SOP-012 in parallel; GDPR clock runs from [Company Name] awareness regardless of vendor notification timing |
| POL-014 | Audit Trail Policy | GxP vendor access to GxP systems creates audit trail records governed by POL-014; vendor must not have access to modify or disable audit trail |
| SOP-004 | Privacy / DPIA Process | High-risk vendor processing triggers DPIA per SOP-004; DPO co-reviews Tier A vendor onboarding |

| Document ID | Title | Relationship |
|---|---|---|
| SOP-006 | Computer System Validation Process | GxP vendor qualification evidence filed in VMF per SOP-006 structure; Validation Closure Report on offboarding |
| SOP-008 | Access Control Process | Vendor access provisioning and deprovisioning lifecycle per SOP-008 |
| SOP-009 | PAM Process | Vendor privileged access JIT and session recording per SOP-009 |
| SOP-010 | IS Risk Assessment Process | Vendor risk register feeds IS Risk Register quarterly; material vendor findings escalated directly |
| SOP-012 | Security Incident Response Process | Vendor incidents activate SOP-012; vendor access suspended immediately |
| EXC-001 | Exception Management Policy and Register | Exceptions to vendor due diligence requirements (e.g., waiver of ISO 27001 for Tier A) require EXC-001 approval at CISO level; maximum 3 months with compensating controls |
| RACI-001 | Roles, Responsibilities and Authorities | Accountability for vendor risk governance |

*— End of Document —*

SOP-013 v1.0 DRAFT | [Company Name] | INTERNAL USE